

INCIDENT RESPONSE PLAN

VitalCloud Health
Integrating SOC, GRC, HIPAA, and Operations

Document Title	Incident Response Plan (IRP)
Document Number	VC-IRP-001
Version	1.0
Classification	Internal — Confidential
Author	GRC Consulting Team / CISO
Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Issue Date	May 19, 2026
Next Review Date	May 19, 2027
Distribution List	SOC Team, GRC Team, HIPAA Officers, IT Operations, Legal, Executive Team

Table of Contents

1. 1. Purpose and Scope
2. 2. Incident Response Team Structure (SOC + GRC + HIPAA + Operations)
3. 3. Severity Classification Matrix
4. 4. Incident Response Lifecycle
5. 5. Ransomware Response Playbook
6. 6. PHI Breach Workflow
7. 7. Containment Steps
8. 8. Evidence Handling and Chain of Custody
9. 9. Escalation Matrix
10. 10. Forensic Preservation Procedures
11. 11. Communications Plan
12. 12. Post-Incident Review and Lessons Learned
13. 13. Appendices

1. Purpose and Scope

This Incident Response Plan (IRP) establishes the framework, procedures, and responsibilities for detecting, responding to, and recovering from information security incidents at VitalCloud Health. It integrates four critical organizational functions:

- SOC (Security Operations Center): Real-time threat detection, monitoring, and initial triage
- GRC (Governance, Risk, and Compliance): Regulatory alignment, risk assessment, and compliance reporting
- HIPAA: Protected Health Information (PHI) breach determination, notification, and remediation
- Operations: Technical containment, system recovery, and business continuity

Purpose: To ensure a coordinated, efficient, and compliant response to security incidents that minimizes harm to patients, protects PHI, maintains telemedicine service availability, and satisfies HIPAA Breach Notification Rule requirements.

Scope: This plan applies to all information systems, networks, applications, IoT medical devices, cloud infrastructure, Legacy Care Clinic systems, and personnel at VitalCloud Health. It covers all incident types including malware, ransomware, unauthorized access, data breaches, insider threats, DDoS attacks, and telemedicine platform compromise.

Regulatory Alignment: This IRP is aligned with ISO 27001:2022 Clause 8.4, HIPAA Security Rule (§164.308(a)(6)), HITECH Act Breach Notification Rule, NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide), and CIS Controls v8.

2. Incident Response Team Structure

The Incident Response Team (IRT) is a cross-functional body integrating SOC, GRC, HIPAA, and Operations personnel. Each function has defined roles, responsibilities, and escalation paths.

2.1 Incident Response Team (IRT) Org Chart

Function	Role / Title	Responsibilities	Contact	Availability
Executive	Incident Commander (CEO/CISO)	Final decision authority, resource allocation, external communications, regulatory liaison	ciso@vitalcloud.health +1-XXX-XXX-XXXX	24/7 On-Call
SOC	SOC Manager / Lead Analyst	Initial detection, triage, classification, containment coordination, threat intelligence	soc@vitalcloud.health SOC Hotline: +1-XXX-XXX-XXXX	24/7 Operations
SOC	SOC Analysts (L1/L2)	Alert monitoring, log analysis, initial containment, ticket creation, evidence collection	soc-l1@vitalcloud.health	24/7 Shift Coverage
GRC	GRC Manager / ISMS Manager	Risk assessment update, control gap analysis, compliance reporting, audit coordination	grc@vitalcloud.health	Business Hours + On-Call
HIPAA	HIPAA Privacy Officer	Breach determination, patient notification, HHS/OCR liaison, media coordination	privacy@vitalcloud.health	24/7 On-Call
HIPAA	HIPAA Security Officer	Technical safeguard assessment, ePHI impact analysis, remediation oversight	security-officer@vitalcloud.health	24/7 On-Call
Operations	IT Operations Manager	System isolation, backup restoration, network segmentation, service recovery	ops@vitalcloud.health	24/7 On-Call
Operations	Cloud/DevOps Engineers	Infrastructure containment, forensic imaging, system rebuilds, failover execution	devops@vitalcloud.health	24/7 On-Call
Operations	Network Engineers	Network isolation, firewall rule updates, traffic analysis, DDoS mitigation	network@vitalcloud.health	24/7 On-Call

Legal	General Counsel / Legal	Regulatory advice, breach notification review, law enforcement liaison, litigation hold	legal@vitalcloud.health	Business Hours + On-Call
HR	HR Director	Employee disciplinary actions, insider threat coordination, workforce communications	hr@vitalcloud.health	Business Hours + On-Call
Communications	Communications / PR Manager	Internal communications, media statements, patient notifications, stakeholder updates	comms@vitalcloud.health	Business Hours + On-Call
External	Forensic Investigators	Digital forensics, malware analysis, root cause determination, expert testimony	forensic@vendor.com	On-Demand
External	Cyber Insurance Carrier	Claim initiation, coverage verification, vendor referrals, financial impact assessment	claims@insurance.com	Business Hours

2.2 Functional Integration During Incidents

The following diagram illustrates how SOC, GRC, HIPAA, and Operations integrate during an incident response:

DETECTION → SOC monitors SIEM, IDS/IPS, EDR, and IoT device alerts. Automated ticketing triggers IRT activation.

TRIAGE → SOC classifies severity. GRC assesses regulatory implications. HIPAA determines if PHI is involved.

CONTAINMENT → Operations executes technical containment (isolation, segmentation). SOC coordinates threat intel.

INVESTIGATION → SOC and Forensics perform root cause analysis. GRC updates risk register. HIPAA assesses breach scope.

REMEDIATION → Operations restores systems. GRC validates control effectiveness. HIPAA oversees PHI protection measures.

RECOVERY → Operations verifies system integrity. SOC monitors for recurrence. GRC and HIPAA approve return to operations.

POST-INCIDENT → All functions participate in lessons learned. GRC updates policies.
HIPAA ensures notification compliance.

3. Severity Classification Matrix

All incidents are classified by severity based on impact to PHI confidentiality, system availability, patient safety, and regulatory exposure. Severity drives response timelines, escalation paths, and resource allocation.

Severity	Criteria	Response Time	Escalation	PHI Impact	Example Scenarios
CRITICAL (P1)	Active breach of PHI >500 patients; Ransomware on production EHR; Telemedicine platform down >1 hour; Life-threatening IoT device compromise	≤ 15 minutes	Immediate CEO/CISO + HIPAA Officers + Legal	Confirmed PHI breach affecting >500 individuals or all ePHI systems compromised	Ransomware encrypting EHR; Mass PHI exfiltration; DDoS taking down telemedicine nationwide; Malicious firmware on heart monitors
HIGH (P2)	PHI breach <500 patients; Unauthorized admin access; Malware on non-production systems; Service degradation >30 minutes	≤ 1 hour	CISO + HIPAA Security Officer + SOC Manager + Operations Manager	Suspected PHI breach affecting <500 individuals or single system compromise with PHI access	Phishing compromise of practitioner account; Malware on clinic workstation; Unauthorized database query; API abuse scraping patient data
MEDIUM (P3)	Suspicious activity with no confirmed PHI access; Failed intrusion attempts; Policy violation; Non-PHI data breach	≤ 4 hours	SOC Manager + GRC Manager + IT Operations Manager	No confirmed PHI access; potential reconnaissance or non-PHI system compromise	Multiple failed login attempts; Port scanning detected; Employee policy violation (non-PHI); Third-party vendor security incident (no PHI)
LOW (P4)	Minor policy violation; Spam; Non-security IT issue; Documentation gap	≤ 24 hours	SOC L1 Analyst + Department Manager	No PHI impact; no security compromise	Employee clicks phishing link (reported immediately); Minor firewall misconfiguration; Outdated antivirus definitions; Training non-compliance

3.1 Severity Classification Decision Tree

SOC Analysts use the following decision tree to classify incident severity within 10 minutes of detection:

1. Is PHI involved or potentially involved? → YES → Proceed to Step 2 | NO → P3/P4
2. Is the PHI breach confirmed (not just suspected)? → YES → Proceed to Step 3 | NO → P2
3. Are >500 patients affected or is the EHR/telemedicine platform compromised? → YES → P1 | NO → P2
4. Is there an active threat (ransomware, ongoing exfiltration, live attacker)? → YES → P1 | NO → Re-evaluate
5. Is patient safety at immediate risk (IoT device, critical care system)? → YES → P1 | NO → P2/P3

4. Incident Response Lifecycle

VitalCloud Health follows the NIST SP 800-61 incident response lifecycle, adapted for healthcare and HIPAA compliance. Each phase involves coordinated actions across SOC, GRC, HIPAA, and Operations.

4.1 PREPARATION

Before an incident occurs, the organization must be prepared to respond effectively.

SOC: Maintain SIEM rules, threat intelligence feeds, playbooks, and detection signatures. Conduct quarterly tabletop exercises.

GRC: Maintain IRP, risk register, and control documentation. Ensure IRP is tested and updated annually.

HIPAA: Maintain breach notification templates, patient contact databases, and HHS reporting procedures.

Operations: Maintain backup systems, failover infrastructure, and system images. Ensure 24/7 on-call coverage.

Key Preparation Activities:

- Annual IRP review and update
- Quarterly phishing simulations and incident drills
- Monthly backup restoration tests
- Weekly threat intelligence briefings
- Maintain contact lists for all IRT members and external vendors

4.2 DETECTION & ANALYSIS

Identify and validate security incidents through monitoring, alerting, and analysis.

SOC Actions:

- Monitor SIEM dashboards, IDS/IPS alerts, EDR notifications, and IoT device anomalies
- Validate alerts to eliminate false positives
- Create incident ticket in ITSM system with initial classification
- Notify SOC Manager within 15 minutes for P1/P2 incidents

GRC Actions:

- Assess if incident triggers any regulatory reporting requirements
- Begin documenting incident for compliance and audit purposes

HIPAA Actions:

- Determine if incident involves PHI (suspected or confirmed)
- Flag for breach assessment if PHI is involved
- Document initial scope of potential PHI exposure

Operations Actions:

- Preserve system state (memory dumps, disk images) before any changes
- Gather initial logs and network traffic captures
- Standby for containment instructions

4.3 CONTAINMENT

Limit the scope and impact of the incident to prevent further damage.

SOC Actions:

- Coordinate containment strategy with Operations
- Monitor for attacker persistence mechanisms
- Update threat intelligence with IOCs

GRC Actions:

- Assess control failures and update risk register
- Document containment actions for compliance review

HIPAA Actions:

- Assess if containment actions may destroy evidence needed for breach determination
- Advise on PHI protection during containment

Operations Actions:

- Execute short-term containment (isolate affected systems, disable accounts, block IPs)
- Implement network segmentation to prevent lateral movement
- Preserve forensic evidence per chain of custody procedures
- Maintain service availability for non-affected systems (especially telemedicine)

Containment Types:

- Short-term: Immediate isolation, account disablement, IP blocking (minutes)
- Long-term: System rebuilds, patch deployment, architecture changes (hours-days)
- Segmentation: VLAN isolation, firewall rule updates, access revocation

4.4 ERADICATION

Remove the root cause and all artifacts of the incident.

SOC Actions:

- Identify and remove malware, backdoors, and persistence mechanisms
- Validate IOCs are fully removed
- Update detection signatures for future prevention

GRC Actions:

- Identify control gaps that allowed the incident
- Initiate corrective action process per ISO 27001 Clause 10

HIPAA Actions:

- Verify no residual PHI exposure remains
- Assess if additional safeguards are needed

Operations Actions:

- Reimage compromised systems from known-good baselines
- Apply all missing patches and security updates
- Reset credentials for all potentially compromised accounts
- Verify system integrity before reconnection to network

4.5 RECOVERY

Restore affected systems and services to normal operations.

SOC Actions:

- Monitor recovered systems for signs of reinfection
- Validate security controls are functioning post-recovery
- Close monitoring gaps that may have contributed

GRC Actions:

- Verify all corrective actions are implemented
- Update risk treatment plan if new risks are identified

HIPAA Actions:

- Approve return to operations only after verifying PHI safeguards
- Document recovery timeline for potential regulatory inquiry

Operations Actions:

- Restore from verified clean backups
- Implement phased return (pilot group → full production)
- Validate telemedicine platform functionality and performance
- Confirm backup systems are operational and tested

Recovery Checklist:

- ☐ All systems scanned and verified clean
- ☐ All patches applied and validated
- ☐ All credentials reset and MFA re-enabled
- ☐ Monitoring and logging fully operational

- ❑ Business continuity plans tested and functional
- ❑ HIPAA Security Officer approval obtained

4.6 POST-INCIDENT ACTIVITY

Learn from the incident and improve the organization's security posture.

SOC Actions:

- Produce final incident report with technical details, timeline, and IOCs
- Update detection rules and playbooks
- Share threat intelligence with industry peers

GRC Actions:

- Conduct post-incident review meeting within 5 business days
- Update risk register and ISMS documentation
- Track corrective actions to closure
- Report to management and audit committee

HIPAA Actions:

- Complete breach determination (if applicable) within 24 hours of containment
- Execute breach notification timeline (see Section 6)
- Document all HIPAA-related actions for OCR inspection
- Update HIPAA policies and training based on lessons learned

Operations Actions:

- Document system changes and configuration updates
- Update disaster recovery and business continuity plans
- Schedule follow-up vulnerability scans and penetration tests

Post-Incident Review Agenda:

1. Incident timeline and chronology
2. What worked well and what did not
3. Root cause analysis findings
4. Control gaps and corrective actions
5. HIPAA breach determination and notification status
6. Updated risk assessment and treatment plan
7. Action items with owners and deadlines

5. Ransomware Response Playbook

Ransomware is a Critical (P1) incident at VitalCloud Health due to the potential for PHI encryption, telemedicine service disruption, and patient safety impact. This playbook provides step-by-step response procedures.

5.1 Ransomware Detection Indicators

- SIEM alerts for mass file encryption events (.locked, .encrypted, .ransomware extensions)
- EDR alerts for suspicious process execution (encryption tools, PowerShell obfuscation)
- User reports of inaccessible files or ransom notes on screens
- Abnormal network traffic to known C2 domains or Tor exit nodes
- Backup system failures or deletion attempts
- IoT device malfunction or unresponsive medical equipment
- Ransom note detected on EHR, telemedicine servers, or clinic workstations

5.2 Ransomware Response Steps (First 60 Minutes)

Time	Action	Responsible Team	Details
0-5 min	ALERT & ACTIVATE	SOC	SOC Analyst detects ransomware indicator. Immediately notifies SOC Manager and activates IRT. Declares P1 incident. Do NOT shut down affected systems yet (preserve memory for forensics).
5-10 min	ISOLATE & SEGMENT	Operations + SOC	Operations isolates affected systems at network level (disconnect from network, disable WiFi, unplug ethernet). SOC blocks known C2 IPs at firewall. Operations segments VLAN to prevent lateral movement. DO NOT power off systems — memory forensics critical.
10-15 min	PRESERVE EVIDENCE	SOC + Forensics	SOC captures memory dumps from affected systems. Forensics team begins disk imaging. Preserve SIEM logs, EDR telemetry, and network traffic captures. Chain of custody initiated. Document all actions with timestamps.
15-20 min	ASSESS PHI IMPACT	HIPAA Officers + SOC	HIPAA Privacy Officer

			and Security Officer assess which systems contain PHI and whether encryption affected ePHI. Determine if this constitutes a breach under HIPAA (unauthorized acquisition/access of PHI). Document scope: number of patients, types of PHI, systems affected.
20-30 min	NOTIFY EXECUTIVES & LEGAL	Incident Commander	CEO/CISO notified. Legal counsel engaged. Cyber insurance carrier contacted. Decision made on whether to engage external forensics and negotiate (if applicable). Communications team placed on standby.
30-45 min	CONTAINMENT EXECUTION	Operations + SOC	Operations disables all compromised accounts and revokes active sessions. SOC hunts for persistence mechanisms (scheduled tasks, registry keys, WMI events). Network-wide scan for additional infected systems. Backup systems verified (immutable backups).
45-60 min	BREACH DETERMINATION	HIPAA Officers + Legal	HIPAA Officers complete preliminary breach risk assessment (probability of compromise × impact). If low probability of compromise → document as non-breach. If breach confirmed → initiate notification timeline (see Section 6). HHS OCR notified if >500 individuals affected (immediately) or within 60 days if <500.

5.3 Ransomware-Specific Decisions

VitalCloud Health does NOT pay ransoms as a matter of policy. The following decisions must be made by the Incident Commander:

1. PAY RANSOM? → NO — Paying does not guarantee decryption, funds criminal activity, and may violate OFAC sanctions.

Alternative: Restore from immutable backups and rebuild affected systems.

2. ENGAGE LAW ENFORCEMENT? → YES — FBI IC3 report filed within 24 hours. Local law enforcement notified for physical threats.

3. ENGAGE EXTERNAL FORENSICS? → YES — For all P1 ransomware incidents. External forensics provides independent root cause analysis.

4. NOTIFY PATIENTS? → If breach confirmed → Yes, within 60 days per HIPAA. If no PHI compromise → No notification required.

5. PUBLIC DISCLOSURE? → If >500 patients affected → Media notification within 60 days. Press release drafted by Communications.

6. REGULATORY REPORTING? → HHS OCR within 60 days (or immediately if >500). State attorneys general as required.

5.4 Ransomware Recovery Procedures

Step 1: Verify Backup Integrity: Operations confirms immutable backups are clean and uncorrupted. Test restoration on isolated system.

Step 2: Rebuild from Baseline: Reimage all affected systems from known-good gold images. Apply all security patches before network connection.

Step 3: Reset All Credentials: Force password reset for ALL users (not just affected). Revoke and reissue API keys, service accounts, and certificates.

Step 4: Verify No Persistence: SOC scans rebuilt systems for malware remnants. EDR validates clean state. Network traffic monitored for 72 hours.

Step 5: Phased Restoration: Restore non-PHI systems first. Test for 24 hours. Then restore PHI systems with enhanced monitoring.

Step 6: Service Validation: Validate telemedicine platform, EHR access, IoT device connectivity, and API functionality before patient-facing restoration.

Step 7: Enhanced Monitoring: 72-hour heightened monitoring post-recovery. SOC analyst dedicated to watching rebuilt systems.

6. PHI Breach Workflow

When an incident involves Protected Health Information (PHI), VitalCloud Health must follow HIPAA Breach Notification Rule (45 CFR §§ 164.400-414) requirements. This workflow integrates SOC detection, HIPAA breach assessment, GRC compliance tracking, and Operations technical remediation.

6.1 Breach Definition (HIPAA)

Under HIPAA, a breach is defined as the unauthorized acquisition, access, use, or disclosure of PHI that compromises the security or privacy of such information.

Exceptions (not considered breaches):

- Unintentional acquisition, access, or use by workforce member acting under authority and in good faith
- Inadvertent disclosure between authorized persons at same organization
- Information disclosed with good faith belief that unauthorized person could not retain the information

Presumption: All unauthorized PHI disclosures are breaches unless a low probability of compromise is demonstrated through risk assessment.

6.2 Breach Assessment Workflow

Phase	Timeline	Actions	Responsible	Deliverable
PHASE 1: Detection	0-1 hour	SOC detects incident involving PHI. Incident ticket created with PHI flag. SOC Manager notifies HIPAA Privacy Officer and Security Officer immediately.	SOC + HIPAA Officers	Incident ticket with PHI classification
PHASE 2: Containment	1-4 hours	Operations contains incident. HIPAA Officers assess scope of PHI exposure: number of patients, types of PHI, systems affected, duration of exposure.	Operations + HIPAA Officers	PHI exposure scope document
PHASE 3: Risk Assessment	4-24 hours	HIPAA Officers conduct risk assessment per §164.402(2): (1) Nature/extent of PHI, (2) Unauthorized person who used PHI, (3) Whether PHI was actually acquired/viewed, (4) Extent to which	HIPAA Officers + Legal	Breach Risk Assessment Report

		risk has been mitigated.		
PHASE 4: Breach Determination	24-48 hours	If low probability of compromise → Document as non-breach with justification. If breach confirmed → Proceed to notification phase. Incident Commander approves determination.	HIPAA Officers + Incident Commander	Breach Determination Memo
PHASE 5: Internal Notification	Within 24 hours of determination	CEO, Board, Legal, and Cyber Insurance notified. GRC updates risk register. Communications team briefed on messaging.	Incident Commander + GRC	Internal notification records
PHASE 6: Individual Notification	Within 60 days of discovery	Affected patients notified via first-class mail (or email if consented). Notification includes: breach description, types of PHI involved, steps taken, contact information, steps individuals should take.	HIPAA Privacy Officer + Communications	Patient notification letters
PHASE 7: HHS/OCR Notification	Within 60 days (or immediately if >500)	HHS Breach Portal submission. If >500 individuals in a state/jurisdiction → Immediate notification to HHS and prominent media outlet.	HIPAA Privacy Officer + Legal	HHS breach report + media release (if applicable)
PHASE 8: Business Associate Notification	Within 60 days	If breach caused by Business Associate → BA must notify VitalCloud. VitalCloud then notifies affected individuals. If BA caused breach → BA may be responsible for individual notification.	HIPAA Privacy Officer + Legal	BAA breach notification records
PHASE 9: Documentation & Retention	Ongoing	All breach documentation retained for 6 years per HIPAA. GRC updates policies. Post-incident	GRC + HIPAA Officers	Breach documentation archive

		review conducted. Corrective actions tracked to closure.		
--	--	--	--	--

6.3 Breach Notification Letter Template (Patient)

The following elements must be included in all patient breach notification letters:

1. Brief description of what happened, including date of breach and date of discovery
2. Types of PHI involved (e.g., names, SSNs, dates of birth, medical record numbers, diagnoses, treatment information)
3. Steps taken by VitalCloud Health to investigate and mitigate harm
4. Steps individuals should take to protect themselves (e.g., credit monitoring, identity theft protection)
5. Contact information for questions (HIPAA Privacy Officer phone/email)
6. Statement that individuals can file complaints with HHS OCR

Sample Opening:

'We are writing to inform you of a security incident at VitalCloud Health that may have affected the privacy of your protected health information. On [DATE], we discovered that [BRIEF DESCRIPTION]. We take the security of your information very seriously and have taken steps to prevent recurrence.'

6.4 HHS Breach Portal Reporting Requirements

For all breaches affecting 500+ individuals:

- Report to HHS immediately (no later than 60 days from discovery)
- Notify prominent media outlet in the state/jurisdiction where affected individuals reside
- Post breach notice on VitalCloud Health website homepage for 90 days

For breaches affecting <500 individuals:

- Report to HHS within 60 days of end of calendar year in which breach was discovered
- No media notification required
- No website posting required (but recommended for transparency)

HHS Breach Portal: https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf

7. Containment Steps

Containment is the most critical phase of incident response. Proper containment prevents further damage, preserves evidence, and maintains essential healthcare services.

Containment actions differ by incident type and severity.

7.1 Containment Decision Matrix

Incident Type	Short-term Containment	Long-term Containment	Evidence Preservation	Service Impact
Ransomware	Isolate infected systems at network level. Disable affected user accounts. Block C2 IPs at firewall. Do NOT power off.	Rebuild from clean images. Apply patches. Reset all credentials. Verify backup integrity before restoration.	Memory dumps before isolation. Disk imaging of affected systems. Preserve ransom notes. Log all containment actions.	Telemedicine and EHR may be offline during rebuild. Maintain manual clinic procedures.
Unauthorized PHI Access	Revoke compromised credentials immediately. Disable user sessions. Isolate affected database/application.	Implement emergency access procedures for critical care. Full access review of similar accounts. Deploy additional monitoring.	Preserve access logs, authentication logs, database query logs. Screenshot unauthorized access evidence.	Minimal if access is revoked quickly. May require temporary suspension of affected user accounts.
Data Exfiltration (Insider/External)	Disable outbound data channels. Block exfiltration IPs/domains. Revoke DLP bypass permissions. Isolate data source.	Full data loss assessment. Implement enhanced DLP rules. Review all data access by compromised account. Legal hold on relevant data.	Preserve DLP logs, network traffic captures, endpoint telemetry. Document exfiltrated data volume and types.	May require temporary suspension of data sharing services. Enhanced monitoring may impact performance.
DDoS Attack	Activate DDoS mitigation service (Cloudflare/AWS Shield). Scale infrastructure. Block attack sources.	Implement rate limiting. Enhance CDN capacity. Review and harden public-facing services. Update DDoS response playbooks.	Preserve traffic logs, attack signatures, mitigation effectiveness data. Document attack duration and peak volume.	Telemedicine may experience degraded performance. Failover to backup infrastructure if primary overwhelmed.
IoT Device Compromise	Isolate device from network. Disable device cloud sync. Alert affected patients if health data at risk.	Firmware update or device replacement. Review all devices of same model. Implement enhanced device monitoring.	Preserve device memory/logs. Document device configuration at time of compromise. Capture network traffic from device.	Patient monitoring may be interrupted. Provide alternative monitoring methods during replacement.
Insider Threat	Revoke all access immediately. Escort employee from facility if physical threat. Preserve workstation state.	HR investigation. Law enforcement referral if criminal activity. Update insider threat detection rules.	Preserve employee's workstation, email, file access history. Do NOT alert employee before evidence preservation.	Minimal if role is non-critical. May require temporary coverage for employee's duties.
Malware (Non-	Isolate infected	Full endpoint	Preserve malware	Single endpoint

Ransomware)	endpoint. Disable email forwarding rules. Block malware C2. Scan adjacent systems.	reimage. EDR deep scan. Update anti-malware signatures. User security awareness retraining.	samples. Document infection vector. Capture process execution timeline.	offline. Minimal service impact if isolated quickly.
-------------	--	---	---	--

7.2 Containment Checklist (All Incidents)

- ☐ Incident severity confirmed and documented
- ☐ IRT activated with appropriate members
- ☐ Affected systems identified and inventoried
- ☐ Evidence preservation initiated before any changes
- ☐ Short-term containment executed (isolation, revocation, blocking)
- ☐ PHI impact assessed by HIPAA Officers
- ☐ Service continuity plan activated if patient care affected
- ☐ Communications plan initiated (internal + external as needed)
- ☐ Law enforcement notified if criminal activity suspected
- ☐ Cyber insurance carrier contacted
- ☐ All containment actions logged with timestamps
- ☐ Chain of custody initiated for forensic evidence
- ☐ Management informed of containment status
- ☐ Long-term containment plan approved by Incident Commander

8. Evidence Handling and Chain of Custody

Proper evidence handling ensures integrity for forensic analysis, regulatory investigations, legal proceedings, and insurance claims. All evidence must follow chain of custody procedures from collection through presentation.

8.1 Evidence Types

Digital Evidence: Memory dumps, disk images, network traffic captures (PCAP), SIEM logs, EDR telemetry, email headers, database query logs

Physical Evidence: Compromised laptops, servers, IoT devices, mobile phones, USB drives, printed documents containing PHI

Documentary Evidence: Incident tickets, containment logs, breach assessment reports, notification records, policy documents

Testimonial Evidence: Witness statements, employee interviews, vendor communications, expert forensic reports

8.2 Chain of Custody Procedures

The Chain of Custody documents who handled evidence, when, where, and why. Any break in the chain may render evidence inadmissible.

1. Collection: SOC Analyst or Forensics team collects evidence using write-blockers and forensic tools. Original evidence is never analyzed directly — working copies are created. Collection time, date, location, and collector identity are recorded.

2. Labeling: Each evidence item receives a unique identifier (EVID-YYYY-NNNN). Label includes: case number, item description, collector name, date/time, storage location. Digital evidence is hashed (SHA-256) immediately upon collection.

3. Storage: Physical evidence stored in locked, access-controlled evidence room with CCTV. Digital evidence stored on encrypted, write-protected media in secure location. Environmental controls protect against magnetic interference, moisture, and temperature extremes.

4. Transfer: Every transfer of evidence requires documentation on Chain of Custody form. Transferor and transferee both sign and date. Reason for transfer documented. Digital evidence transfers use encrypted channels with integrity verification.

5. Analysis: Forensic analysis conducted on verified working copies only. Analysis methods documented. Tools used are court-accepted and validated. All analysis findings documented in forensic report with supporting screenshots and logs.

6. Presentation: Evidence presented in regulatory, legal, or insurance proceedings as needed. Forensic expert available for testimony. Chain of Custody form accompanies evidence. Evidence returned to secure storage after proceedings.

7. Disposition: Evidence retained per legal hold requirements (typically 6+ years for HIPAA). Disposition approved by Legal and GRC. Secure destruction documented when retention period expires.

8.3 Chain of Custody Form Template

Evidence ID	Description	Collected By	Date/Time	Hash (SHA-256)	Storage Location
EVID-2026-0001	EHR Server Disk Image (Server-ERH-01)	Forensics Team Lead	2026-05-19 14:30 UTC	a1b2c3d4... (truncated)	Evidence Room A-12, Encrypted Drive
EVID-2026-0002	Memory Dump (Workstation-LEG-05)	SOC Analyst L2	2026-05-19 14:45 UTC	e5f6g7h8... (truncated)	Evidence Room A-12, Encrypted Drive
EVID-2026-0003	Network Traffic Capture (Ransomware C2)	Network Engineer	2026-05-19 14:20 UTC	i9j0k1l2... (truncated)	SIEM Archive, Encrypted Storage

8.4 Evidence Integrity Verification

All digital evidence integrity is verified using cryptographic hashing:

- SHA-256 hashes are calculated at collection, transfer, and analysis points
- Any hash mismatch triggers immediate investigation for tampering or corruption
- Hash values are recorded on Chain of Custody form and in forensic report
- Write-blockers and read-only mounts prevent accidental modification
- Time synchronization (NTP) ensures accurate timestamps across all evidence

9. Escalation Matrix

The escalation matrix defines when and how incidents are escalated based on severity, scope, and regulatory implications. Clear escalation paths ensure timely executive involvement, regulatory compliance, and resource allocation.

9.1 Escalation by Severity and Time

Severity	Initial Response	15-Min Escalation	1-Hour Escalation	4-Hour Escalation	24-Hour Escalation
CRITICAL (P1)	SOC Analyst → SOC Manager	CISO + HIPAA Privacy Officer + HIPAA Security Officer + Legal	CEO + Board Chair + Cyber Insurance	External Forensics + FBI IC3 + HHS OCR (if >500)	Media/PR (if public) + State AGs + All stakeholders
HIGH (P2)	SOC Analyst → SOC Manager	CISO + HIPAA Security Officer	HIPAA Privacy Officer + Legal + GRC Manager	CEO (if PHI >100 patients or service outage >4hrs)	Board notification (if significant financial/reputational impact)
MEDIUM (P3)	SOC Analyst → SOC Manager	GRC Manager + IT Operations Manager	CISO (if trend indicates systemic issue)	Department Head (if policy violation or insider threat)	Annual incident trend review
LOW (P4)	SOC Analyst (self-resolve or escalate)	SOC Manager (if unclear classification)	Department Manager (if policy violation)	GRC Manager (if recurring pattern)	Quarterly metrics review

9.2 Escalation Triggers (Beyond Severity)

Escalation may also be triggered by specific conditions regardless of initial severity classification:

- PHI breach confirmed affecting any number of patients → Immediate HIPAA Officer + Legal escalation
- Ransomware on any system containing PHI → Immediate P1 escalation regardless of patient count
- Telemedicine platform unavailable >30 minutes → Operations Manager + CISO escalation
- IoT medical device (heart monitor) compromised → Patient Safety Officer + FDA notification
- Insider threat with privileged access → HR + Legal + CISO immediate escalation
- Third-party vendor breach affecting VitalCloud PHI → Legal + GRC + HIPAA Officer escalation
- Multiple simultaneous incidents → Automatic P1 escalation (possible coordinated attack)
- Media inquiry about security incident → Communications + CEO + Legal immediate escalation
- Law enforcement contact regarding VitalCloud → Legal + CISO + CEO immediate escalation

- • Regulatory inquiry (OCR, state AG) → Legal + HIPAA Officers + CEO immediate escalation

9.3 Escalation Communication Protocol

Escalation communications follow strict protocols to ensure rapid, accurate information flow:

PRIMARY CHANNELS:

- P1/P2: Phone call + Secure messaging (Signal/Wire) + Email confirmation
- P3: Secure email + ITSM ticket update
- P4: ITSM ticket update + Daily SOC summary

REQUIRED INFORMATION IN ESCALATION:

1. Incident ID and severity classification
2. Brief description of incident and affected systems
3. Confirmed or suspected PHI involvement
4. Current containment status
5. Patient safety impact (if any)
6. Service availability impact
7. Actions taken to date
8. Resources needed from escalated party
9. Next steps and timeline

ESCALATION ACKNOWLEDGMENT:

- Escalated party must acknowledge receipt within 15 minutes (P1) or 1 hour (P2)
- If no acknowledgment, automatic re-escalation to next level
- All escalations documented in incident ticket with timestamps

10. Forensic Preservation Procedures

Forensic preservation ensures that digital evidence is collected, stored, and analyzed in a manner that maintains integrity, authenticity, and admissibility for regulatory, legal, and insurance purposes.

10.1 Pre-Preservation Considerations

Before collecting forensic evidence, the following must be determined:

1. Is the system currently running or powered off?
 - Running: Capture volatile memory (RAM) FIRST before disk imaging. Live system artifacts are lost on shutdown.
 - Powered off: Do NOT power on. Perform dead disk imaging to prevent evidence modification.
2. Is the system business-critical?
 - If yes, coordinate with Operations for minimal-impact collection (e.g., memory dump during maintenance window).
 - If no, isolate immediately and preserve full system state.
3. Is PHI on the system?
 - If yes, HIPAA Officers must approve collection method to ensure no additional PHI exposure.
 - Encryption keys must be preserved separately (see Section 10.4).
4. Is the incident ongoing (active attacker)?
 - If yes, prioritize live memory capture and network traffic over disk imaging.
 - Document all actions to avoid alerting the attacker.

10.2 Memory (RAM) Preservation

Tool Selection: Use court-accepted tools: Magnet RAM Capture, FTK Imager, or WinPmem. Tools must be validated and documented.

Collection Method: Run memory capture tool from external USB (never write to target disk). Store output on external encrypted drive.

Hash Verification: Calculate SHA-256 hash of memory dump immediately after collection. Record in Chain of Custody form.

Documentation: Record: system name, OS version, RAM size, collection time, collector identity, tool version, output filename.

Storage: Store memory dump on encrypted, write-protected media. Maintain in secure evidence storage.

10.3 Disk Preservation

Write-Blocking: Always use hardware write-blockers (Tableau, WiebeTech) when connecting original media to forensic workstation.

Imaging Method: Create bit-for-bit forensic image (E01 or DD format). Verify image integrity with SHA-256 hash.

Verification: Compare source disk hash to image hash. Must match exactly. Document any discrepancies.

Working Copies: All analysis conducted on working copies (RAW or mounted images). Original image never modified.

Cloud Storage: For cloud-based systems (AWS/Azure), use provider forensic tools: AWS EBS snapshots, Azure disk snapshots. Coordinate with cloud provider and preserve snapshot metadata.

10.4 Network Traffic Preservation

Network traffic captures (PCAP) are critical for understanding attack vectors, C2 communications, and data exfiltration.

- Full packet capture: Use tcpdump, Wireshark, or network appliances (Riverbed, Gigamon) to capture all traffic
- NetFlow/sFlow: Preserve flow records for connection metadata when full capture is impractical
- Proxy logs: Preserve web proxy logs for HTTP/HTTPS traffic analysis
- Firewall logs: Preserve state table and rule hit counts
- DNS logs: Preserve query logs for C2 domain identification

Retention: Network captures retained for minimum 90 days (P1/P2 incidents retained for 6+ years per HIPAA).

10.5 Log Preservation

All relevant logs must be preserved immediately to prevent rotation or deletion:

- SIEM logs: Export incident-related queries to immutable storage
- EDR telemetry: Preserve endpoint detection and response records
- Authentication logs: Preserve Active Directory, SSO, and MFA logs
- Database logs: Preserve query logs, access logs, and audit trails
- Application logs: Preserve web server, API gateway, and application-specific logs
- Cloud logs: Preserve CloudTrail, Azure Activity Logs, and VPC Flow Logs
- Email logs: Preserve mail server logs and email content (if relevant)

Log Integrity: All exported logs must be hashed (SHA-256) and signed. Log timestamps verified against NTP.

10.6 Forensic Analysis Standards

All forensic analysis follows established standards to ensure admissibility:

- NIST SP 800-86: Guide to Integrating Forensic Techniques into Incident Response
- ISO/IEC 27037: Guidelines for identification, collection, acquisition, and preservation of digital evidence
- ACPO Guidelines (UK) or equivalent local standards
- Daubert Standard (US): Scientific validity and peer review of methods

Forensic Report Contents:

1. Case summary and incident description
2. Evidence inventory with Chain of Custody references
3. Analysis methodology and tools used
4. Timeline of attacker activity
5. IOCs (Indicators of Compromise) identified
6. Root cause determination
7. Recommendations for prevention
8. Appendices with supporting screenshots, logs, and hashes

11. Communications Plan

Effective communication during an incident is critical for coordination, compliance, reputation management, and patient trust. This plan defines what to communicate, to whom, when, and through which channels — integrating SOC, GRC, HIPAA, and Operations perspectives.

11.1 Communication Principles

- **Accuracy:** All communications must be factual and verified. No speculation or unconfirmed information.
- **Timeliness:** Communications occur at defined intervals based on severity. Delays may violate HIPAA or worsen reputational damage.
- **Confidentiality:** Internal communications use secure channels. External communications are approved by Legal and Communications.
- **Consistency:** All spokespeople use approved messaging. No individual employees make public statements.
- **Transparency:** Patients and regulators receive honest, clear information about breaches and remediation.
- **Documentation:** All communications are logged, archived, and retained per HIPAA (6 years).

11.2 Internal Communications

Audience	Trigger	Message	Channel	Owner
IRT Members	All P1/P2 incidents	Incident status, containment actions, resource needs, next steps	Secure messaging + Phone + ITSM	Incident Commander
Executive Team	P1 incidents or confirmed PHI breach	Executive summary, business impact, regulatory exposure, public risk	Secure email + Phone	CISO
Board of Directors	P1 incidents or >500 patient breach	Strategic impact, financial exposure, regulatory actions, insurance status	Secure board portal + Phone	CEO
All Employees	Service outage >2hrs or confirmed breach	Awareness of incident, expected impact, reporting instructions, no speculation policy	Intranet + Email + All-hands	Communications Manager
Department Heads	Incidents affecting their systems	System status, recovery timeline, temporary procedures, staff instructions	Email + Phone	IT Operations Manager
Clinic Staff	Legacy clinic system incidents	Patient care continuity instructions, manual	Phone + SMS + Email	Clinic Operations Manager

		procedures, point of contact		
Independent Practitioners	Telemedicine or portal incidents	Platform status, alternative access methods, patient communication guidance	Secure portal + Email	HIPAA Privacy Officer

11.3 External Communications

Audience	Trigger	Timeline	Message	Channel	Owner
Affected Patients	Confirmed PHI breach	Within 60 days of discovery	Breach notification letter: what happened, what PHI, steps taken, protective steps, contact info	First-class mail + Email (if consented)	HIPAA Privacy Officer
HHS / OCR	Confirmed breach	Within 60 days (<500) or immediately (>500)	Breach report: entity info, breach type, PHI types, patients affected, discovery date, mitigation	HHS Breach Portal	HIPAA Privacy Officer
State Attorneys General	Confirmed breach (state laws)	Per state requirements (typically 60 days)	Breach notification per state health data breach laws	State AG portals / Mail	Legal + HIPAA Privacy Officer
Media	Confirmed breach >500 patients	Within 60 days	Press release: factual summary, steps taken, patient resources, no speculation	Press release + Website	Communications Manager + Legal
Cyber Insurance	All P1/P2 incidents	Within 24 hours	Incident summary, estimated impact, preservation of evidence, coverage verification	Phone + Secure email	CISO + Legal
Law Enforcement	Criminal activity suspected	Within 24 hours	Incident summary, evidence preserved, cooperation offer, point of contact	FBI IC3 + Local LE	Legal + CISO
Business Associates	BA caused or affected by breach	Within 60 days or per BAA	Breach notification per BAA terms, cooperation requirements,	Secure email + Phone	HIPAA Privacy Officer + Legal

			remediation expectations		
National Insurance Provider	Any incident affecting contract eligibility	Within 48 hours	Incident summary, PHI impact, containment status, compliance assurance	Secure email + Phone	CISO + CEO
Regulatory Bodies (non-HHS)	FDA (IoT), SEC (if applicable)	Per regulatory requirements	Incident summary, device/system impact, corrective actions, patient safety assessment	Regulatory portals	Legal + Relevant Officer

11.4 Communication Templates

Pre-approved communication templates ensure rapid, consistent, and compliant messaging:

Template Inventory:

- TPL-001: Internal IRT Status Update (hourly during P1)
- TPL-002: Executive Summary Brief (P1/P2 incidents)
- TPL-003: Employee Awareness Notice (service outage)
- TPL-004: Patient Breach Notification Letter (HIPAA-compliant)
- TPL-005: HHS Breach Portal Submission
- TPL-006: Media Statement / Press Release
- TPL-007: Business Associate Breach Notification
- TPL-008: Law Enforcement Cooperation Letter
- TPL-009: Cyber Insurance Claim Notification
- TPL-010: Patient FAQ (website posting)

All templates are stored in the Incident Response SharePoint/Confluence repository and reviewed annually by Legal and Communications.

11.5 Social Media and Public Monitoring

During incidents, especially breaches, social media monitoring is essential:

- Communications team monitors Twitter, Reddit, news sites, and patient forums for mentions of VitalCloud
- Any patient complaints or media inquiries are escalated to Incident Commander within 15 minutes
- Pre-approved holding statements are ready for social media responses
- No employee posts about incidents on personal social media (disciplinary action applies)
- Dark web monitoring for leaked PHI is conducted by SOC threat intelligence team

If leaked PHI is discovered on dark web or public forums:

1. Immediately preserve evidence (screenshots, URLs, timestamps)
2. Notify Legal and HIPAA Privacy Officer within 30 minutes
3. Do NOT attempt to download or interact with leaked data (may destroy evidence)
4. Engage external dark web monitoring vendor for takedown requests

12. Post-Incident Review and Lessons Learned

Every incident, regardless of severity, requires a post-incident review to identify improvements, update controls, and prevent recurrence. Reviews integrate SOC, GRC, HIPAA, and Operations perspectives.

12.1 Review Timeline

Milestone	Timeline	Participants	Deliverable
Initial Debrief	Within 24 hours of containment	IRT Core Team (SOC, Operations, HIPAA)	Hot wash notes, immediate action items
Technical Forensics Report	Within 5 business days	SOC + External Forensics	Forensic report with IOCs, timeline, root cause
HIPAA Breach Assessment	Within 24 hours of containment	HIPAA Officers + Legal	Breach determination memo (if applicable)
Full Post-Incident Review	Within 5 business days	All IRT members + Executive Sponsor	PIR report with findings and recommendations
Corrective Action Plan	Within 10 business days	GRC + Relevant Control Owners	CAP with owners, deadlines, validation criteria
Policy/Procedure Updates	Within 30 days	GRC + Policy Owners	Updated IRP, policies, playbooks, training materials
Management Review	Next quarterly review	CISO + Executive Team	Incident trends, metrics, resource needs, strategic changes

12.2 Post-Incident Review Agenda

- 1. Incident Chronology: Detailed timeline from detection through recovery, including all decisions and actions
- 2. Detection Effectiveness: Were detection tools effective? Was there a delay? Could this have been detected earlier?
- 3. Response Effectiveness: Did containment work as planned? Were there delays or gaps in execution?
- 4. Communication Effectiveness: Were stakeholders informed appropriately? Any communication failures?
- 5. HIPAA Compliance: Was breach determination accurate and timely? Were notifications compliant?
- 6. Root Cause Analysis: What allowed the incident to occur? Technical, process, or human factors?
- 7. Control Gaps: Which controls failed or were missing? How should they be strengthened?
- 8. Lessons Learned: What worked well? What should be done differently?
- 9. Corrective Actions: Specific, measurable actions with owners and deadlines
- 10. Metrics Update: Update MTTD, MTTR, and other KPIs. Compare to targets.
- 11. Knowledge Sharing: Update playbooks, train staff, share anonymized lessons with industry peers

12.3 Corrective Action Tracking

All corrective actions from post-incident reviews are tracked in the Corrective Action Register:

- Action ID, Description, Owner, Target Date, Status (Open/In Progress/Closed), Verification Method
- GRC Manager tracks all actions to closure
- Overdue actions escalated to CISO weekly
- Closed actions verified through testing, audit, or review
- Corrective actions integrated into ISMS Improvement Plan (Clause 10)

13. Appendices

Appendix A: Contact Directory

Role	Name	Phone	Email	Backup Contact
Incident Commander (CEO)	[CEO Name]	+1-XXX-XXX-XXXX	ceo@vitalcloud.health	[COO Name]
CISO	[CISO Name]	+1-XXX-XXX-XXXX	ciso@vitalcloud.health	[Deputy CISO Name]
SOC Manager	[SOC Manager Name]	+1-XXX-XXX-XXXX	soc@vitalcloud.health	[SOC Lead Name]
HIPAA Privacy Officer	[HPO Name]	+1-XXX-XXX-XXXX	privacy@vitalcloud.health	[Deputy HPO Name]
HIPAA Security Officer	[HSO Name]	+1-XXX-XXX-XXXX	security-officer@vitalcloud.health	[Deputy HSO Name]
GRC Manager	[GRC Name]	+1-XXX-XXX-XXXX	grc@vitalcloud.health	[ISMS Manager Name]
IT Operations Manager	[Ops Name]	+1-XXX-XXX-XXXX	ops@vitalcloud.health	[DevOps Lead Name]
Legal Counsel	[Legal Name]	+1-XXX-XXX-XXXX	legal@vitalcloud.health	[External Counsel Name]
Communications Manager	[Comms Name]	+1-XXX-XXX-XXXX	comms@vitalcloud.health	[PR Agency Name]
Cyber Insurance	[Claims Handler]	+1-XXX-XXX-XXXX	claims@insurance.com	[Broker Name]
External Forensics	[Vendor Contact]	+1-XXX-XXX-XXXX	forensic@vendor.com	[Backup Vendor]
FBI IC3	N/A	1-800-CALL-FBI	www.ic3.gov	Local FBI Field Office
HHS OCR	N/A	1-800-368-1019	ocrmail@hhs.gov	Regional OCR Office

Appendix B: Key Definitions

Breach (HIPAA): The acquisition, access, use, or disclosure of PHI in a manner not permitted under the HIPAA Privacy Rule that compromises the security or privacy of the PHI.

Chain of Custody: The chronological documentation showing the seizure, custody, control, transfer, analysis, and disposition of evidence.

Containment: Actions taken to limit the scope or magnitude of an incident.

ePHI: Electronic Protected Health Information — PHI created, received, maintained, or transmitted in electronic form.

Forensic Image: Bit-for-bit copy of digital media created using write-blocking and hashing to preserve evidence integrity.

Incident: An occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of information assets.

Incident Commander: The individual with ultimate authority and accountability for incident response decisions.

IOCs (Indicators of Compromise): Artifacts observed on a network or in an operating system that indicate a computer intrusion.

MTTD: Mean Time to Detect — average time between incident occurrence and detection.

MTTR: Mean Time to Respond — average time between detection and containment.

PHI: Protected Health Information — individually identifiable health information held or transmitted by a covered entity.

Ransomware: Malicious software that encrypts files and demands payment for decryption.

SOC: Security Operations Center — team responsible for real-time security monitoring and incident detection.

Appendix C: Regulatory References

- HIPAA Privacy Rule (45 CFR Part 160 and Subparts A and E of Part 164)
- HIPAA Security Rule (45 CFR Part 160 and Subparts A and C of Part 164)
- HIPAA Breach Notification Rule (45 CFR §§ 164.400-414)
- HITECH Act (Public Law 111-5, Title XIII)
- ISO/IEC 27001:2022 — Clause 8.4 (Information Security Incident Management)
- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
- NIST SP 800-86 — Guide to Integrating Forensic Techniques into Incident Response
- CIS Controls v8 — Control 17 (Incident Response Management)
- FDA Cybersecurity Guidance for Medical Devices
- State Health Data Breach Notification Laws (all applicable states)

Document Approval

This Incident Response Plan has been reviewed and approved by the following authorized personnel:

Name	Title	Signature	Date
[Name]	Chief Executive Officer (CEO)	_____	_____
[Name]	Chief Information Security Officer (CISO)	_____	_____
[Name]	HIPAA Privacy Officer	_____	_____
[Name]	HIPAA Security Officer	_____	_____
[Name]	GRC Manager / ISMS Manager	_____	_____

This document is the property of VitalCloud Health. Unauthorized disclosure, copying, or distribution is prohibited. All IRT members must acknowledge receipt and understanding of this plan. This plan shall be reviewed at least annually or upon significant organizational, technological, or threat landscape changes.